



File No.: EXP202311911

SANCTIONING PROCEDURE RESOLUTION

From the procedure initiated by the Spanish Agency for Data Protection and based on the following:
BACKGROUND

FIRST: Mr. A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on July 12, 2023. The complaint is directed against DIGI SPAIN TELECOM, S.L. with NIF B84919760 (hereinafter, the respondent or DIGI). The reasons for the complaint are as follows:

- That on April 6, 2021, he was a victim of identity theft, resulting in an unauthorized transfer through his bank account.
- That he is the holder of the telephone line ***PHONE.1 with the respondent.
- That at 14:21 hours, a duplicate of his card was made, remaining blocked until 17:30 hours when it was unlocked from the DIGI store in ***LOCATION.1.
- That the request for that duplicate card was not made by him, nor did he receive any prior communication via SMS, email, or phone call. He claims that he also did not use any type of electronic signature system to verify his identity despite being required to do so.
- That DIGI did not verify the identity of the person who made the duplicate of his SIM card, violating Article 6.1 of the GDPR.

And, he provides the following relevant documentation:

- Report of the complaint filed with the Civil Guard - Post of ***LOCATION.1, where the following statements from the complainant are recorded: "(...)."
- Proof of the unauthorized transfer by the complainant for the amount of (...) euros dated April 6, 2021, from the entity IBERCAJA direct.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the respondent for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was acknowledged on September 11, 2023, as recorded in the acknowledgment of receipt in the file. On October 11, 2023, this Agency received a response indicating: << that the only way to initiate the procedure for requesting a duplicate of the SIM card that DIGI made available to its individual clients at the time of the events was exclusively by appearing before one of our distributors (dealers) and identifying oneself as the holder of the line by presenting their original identity document.

(...).

(...).

(...).

(...).

(...).

(...).

(...).

(...).

(...).

(...).

THIRD: On October 12, 2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH: According to the report obtained from the AXESOR tool, the entity DIGI SPAIN TELECOM, S.L. is a large company established in 2006, with a business volume of 496,444,000 euros in 2022.

FIFTH: On March 19, 2024, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against the respondent,

C/ Jorge Juan, 6

in accordance with the provisions of Articles 63 and 64 of the LPACAP, for the alleged infringement of Article 6.1 of the GDPR, classified in Article 83.5 of the GDPR.

SIXTH: Once the aforementioned initiation agreement was notified, on March 25, 2024, in accordance with the rules established in the LPACAP, the party being claimed submitted a written statement of allegations on April 10, 2024, in which, in summary, it is stated that it reiterates the statements previously made in the transfer, first chronologically outlining how the events occurred, indicating the security protocol and the measures adopted in relation to these events, stating that DIGI has not provided the alleged offenders with personal information of the claimant other than that which they already had prior, having obtained it through email.

It asserts that, consequently, it is not possible to associate DIGI with the performance of an unauthorized processing of personal data, given that its actions are limited to complying with its processes and obligations.

That is to say, during the process of requesting and delivering the duplicate, there is a processing of the personal data provided to DIGI in order for it to verify the identity of the interlocutor in person. Furthermore, DIGI states that it is evidenced that the identity theft and the illegitimate access to the claimant's data occurred prior to any contact with DIGI, as the alleged impersonator had in their possession the personal data of the claimant.

On the other hand, it points out that the AEPD unequivocally imposes on DIGI an objective liability, in which, regardless of the diligence and measures deployed, the culpability of the entity is declared. It argues that the AEPD seems to confuse the concept of proactive responsibility with the obligation of result imposed by objective liability. In its opinion, in the present case, there is evidence of strict control, both prior to and after the request for the duplicate, the establishment of prior and subsequent measures, as well as the existence of measures aimed at preventing such practices beforehand. For this reason, the party being claimed considers that the initiation agreement is not in accordance with the law, as it imposes on DIGI an obligation of result, based solely on the harmful outcome produced by the fraudulent activity of a third party, without taking into account the diligence exercised and without considering the deployment of technically adequate and implemented measures.

Additionally, it expresses a lack of proportionality in the imposition of the sanction given that, in its opinion, it has demonstrated having acted with due diligence in the identification and detection of the fraud, acting immediately to limit and mitigate the harm caused to the Claimant. It considers that the sanction included in the initiation agreement is, in any case, disproportionate, taking into account the circumstances and content of the alleged infringements, which it categorically denies.

It is also stated that none of the circumstances indicated as aggravating factors in the initiation agreement are present.

On the other hand, it is noted that according to the provisions of Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, the following mitigating circumstances, which have not been considered in the appropriate assessment of the sanction, are present:

- The respondent party effectively resolved the incident subject to the complaint (Art. 83.2 c);
- At no time were special categories of data processed (Art. 83.2 g) GDPR).
- The degree of cooperation of DIGI with the AEPD in order to remedy an alleged infringement and mitigate its possible adverse effects: it has been demonstrated that all information requests made by this Agency were responded to in a timely manner. Furthermore, DIGI provided, in the first information request, prior to being requested by the AEPD, all contractual and supporting documentation related to the present case, voluntarily expressing its good faith and intention to collaborate with the authority

(Art. 83.2 f) GDPR).

- The non-existent benefit obtained by DIGI as a result of the data processing involved in this procedure. In any case, DIGI has been harmed, as already noted, by being affected by fraud committed by a third party, which has forced it to rectify the situation caused and conduct investigations, with the associated costs (Art. 83.2 k) 24 GDPR). It should be emphasized that this not only does not represent an economic benefit, but DIGI has been harmed by the error made by its provider, despite having all the necessary measures and guarantees in place.

For all the above reasons, the quantification of the possible sanction to be imposed on DIGI in relation to the alleged breach of the obligations of Article 6.1 of the GDPR indicates that it should be limited to a warning and, ultimately, that the proposal contained in the Initiation Agreement notified to DIGI should be moderated or adjusted, taking into account its arguments.

SIXTH: On April 11, 2024, the instructor of the procedure agreed to carry out the following evidence:

<<1. The complaint filed by A.A.A. and its documentation, the documents obtained and generated during the admission phase of the complaint, which are part of procedure AT/04498/2023, are reproduced for evidentiary purposes. 2. Likewise, the allegations to the initiation agreement of the referenced sanctioning procedure, presented by DIGI SPAIN TELECOM, S.L., and the accompanying documentation are reproduced for evidentiary purposes>>.

SEVENTH: On August 2, 2024, a resolution proposal was made, proposing that the Director of the Spanish Agency for Data Protection...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/19

impose a sanction on DIGI SPAIN TELECOM, S.L. with NIF B84919760 for an infringement of Article 6.1 of the GDPR, classified under Article 83.5 a) of the GDPR, with a fine of 200,000 euros (two hundred thousand euros).

EIGHTH: Once the proposed resolution was notified, on August 12, 2024, the responding party submitted a written statement of allegations on August 27, 2024, in which, in summary, it argues that it reiterates the allegations previously presented. It states that there has been no unlawful processing of data, as its actions were diligent, in compliance with the established procedure, and that the effects were caused by the actions of a third party, and that DIGI did not provide any personal data of the interested party. It asserts that the commission of this type of fraud originates from an initial breach of the confidentiality of the personal data of the interested party before their financial institution, usually through “phishing” by which their banking credentials are obtained.

Furthermore, it points out that the report issued by the European Union Agency for Cybersecurity confirms that to carry out a fraudulent SIM duplication, the scammer needs access to some of the personal data of the victim, a customer of the operator. That is to say, cybercriminals have personal data of their victims prior to approaching the Mobile Network Operator. It indicates that this is what happened in the present case; the victim lost control over their personal data and identity documentation in favor of the impersonator before the latter contacted DIGI. In other words, it is through the phishing attack that the victim loses control over their personal data, and it is this fact that triggers and enables the commission of the fraud.

The responding party maintains that it has been enumerating in its writings to the AEPD the measures related to the procedures for obtaining duplicates of SIM cards; however, the AEPD has not assessed these measures.

On the other hand, it indicates that, despite the commission of an undesirable outcome, the Agency must evaluate the established procedure, as well as its review and implementation of improvements. It also considers that the Proposal is not legally justified, as it imposes on DIGI an obligation of result, consisting of establishing infallible measures regarding risks that are imposed on it by third parties who, unilaterally, have decided to outsource their own security obligations as data controllers without DIGI's consent. It goes so far as to attribute a violation of Article 6.1 of the GDPR based solely on the harmful result produced by the fraudulent intervention of a third party that surpasses security

measures, without considering the diligence employed, and without taking into account the deployment of technically adequate measures implemented regarding a processing for which DIGI does not determine either the purpose or the means.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

6/19

The responding party states that it cannot foresee or know what the applicable duty of diligence is, as the AEPD demands the achievement of a result and zero risk.

On the other hand, it expresses its views on the lack of proportionality of the proposed sanction.

In this regard, the responding party disagrees with the aggravating factor applied:

Connection between its activity and the processing of personal data of customers or third parties (Article 83.2 K of the GDPR in relation to Article 76.2 b of the LOPDGDD).

It indicates that this aggravating factor must be contextualized with the deployment of measures carried out by DIGI. In this sense, it states that the processing of data does not arise from an intention of the entity, but rather the commission of a crime of which DIGI is the injured party. Therefore, this aspect should not be interpreted as an aggravating factor.

Regarding the mitigating factors not applied by the Agency when assessing the sanction, the responding party believes that the following should be taken into account:

- That it proceeded to effectively resolve the incident subject to the complaint as soon as it became aware of the facts.

On the other hand, it indicates that the claimant's mobile line was active on the allegedly fraudulent SIM for less than three hours. In that brief period, DIGI took swift and effective measures, suspending the mobile service on the line that was activated allegedly irregularly and returning control to the claimant. This action demonstrates significant diligence on the part of DIGI.

- At no time were special categories of data processed (Art. 83.2 g GDPR).

The responding party states that DIGI has not processed special category data, and that name, surname, and ID number do not fall under special categories (Art. 9 of the GDPR).

- The degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement.

It also points out that it has responded in a timely manner to all information requests made by this Agency (Art. 83.2 f GDPR).

- The nonexistent benefit obtained.

Additionally, it states that it has been harmed, as it has been affected by the commission of fraud by a third party, which has forced it to remedy the situation caused and carry out investigations, with the associated costs (Art. 83.2 k GDPR).

For all the above reasons, the responding party requests that a resolution be issued indicating the filing of the Procedure or, subsidiarily, concluding the procedure.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

7/19

by means of a warning and, ultimately, if it deems appropriate to impose a sanction, to moderate or adjust the sanction.

From the actions taken in the present procedure and the documentation in the file, the following have been established:

PROVEN FACTS

FIRST. – On April 6, 2021, a third party appeared at a DIGI point of sale to obtain a duplicate of the claimant's SIM card.

SECOND. – From the two screenshots of the DIGI system provided on October 11, 2023, in response

to the information request from this Agency to the defendant party, which is included in the file, it is evident that two duplicates of the claimant's SIM card were issued.

- In the first of them, it is recorded that the duplicate of the SIM card was made on April 6, 2021, at 14:21 at a DIGI point of sale, leaving the claimant without service.

- In the second of them, it is recorded that a new duplicate of the SIM was made such that the initial duplicate became inactive, on April 6, 2021, at 16:47 hours, restoring the service to the claimant.

THIRD. – From the screenshots provided by DIGI, dated October 11, 2023, it is recorded that the identity verification process of the applicant applied to the present case at the time of the events, for obtaining a duplicate of a SIM card, was as follows:

- (...).
- (...).
- (...).
- (...).
- (...).
- (...).

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/19

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Response to the allegations presented

In response to the allegations presented by the defendant entity, the following should be noted:

The fraudulent intervention of a third party has revealed the inadequate risk analysis, as well as the insufficient implementation, review, and control of security measures by the operator. A third party unrelated to the data subject has surpassed the security measures established by DIGI. This shows us that the identification of the data subject was not carried out with sufficient guarantees, regardless of whether the identification was made by the data subject themselves or by a third party fraudulently.

In summary, a lack of appropriate security measures and a failure to comply with the obligations arising from proactive responsibility, especially when the "errors" persist over time.

In this regard, it should be noted that precisely because we are dealing with the fraud of a third party, it is necessary to ensure that the person to whom the duplicate of the SIM card is issued is who they claim to be, and appropriate preventive measures must be adopted to verify the identity of a person whose data will be subject to processing, as recognized in Legal Ground Seventh of the SAN, SCA, of May 5, 2021 ("On the other hand, regarding the fact that we are facing the fraud of a third party, as we stated in the SAN of October 3, 2013 (Rec. 54/2012) -: 'Precisely for that reason, it is necessary to ensure that the person contracting is who they really say they are, and appropriate preventive measures must be adopted to verify the identity of a person whose personal data will be subject to processing...").

Throughout this procedure, DIGI has repeatedly stated that fraudulent duplicates of the cards have

occurred after fraudsters have surpassed their security policy. It considers that it is inevitable that despite the existence of the security policy, there may be cases in which, through certain mechanisms, this security policy may be fraudulently surpassed without any reproach to DIGI.

However, it has been proven that DIGI's security policy has been insufficient for the adequate protection of the fundamental rights of the claimant whose SIM card has been fraudulently duplicated. Regarding the assertion that DIGI has not provided the alleged criminals with personal information of the claimant other than what they already had prior and that, consequently, there has been no unauthorized processing...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
9/19

of personal data.

Indeed, the issuance of a duplicate is not sufficient to carry out banking operations on behalf of the holders; certainly, to complete the fraud, it is necessary for a third party to "impersonate the identity" of the data holder before the financial entity.

However, to be able to carry out such operations via mobile phone, it is necessary to have access to it, and one of the means is, precisely, the obtaining of a duplicate card. When such a duplicate is issued to a third party different from its holder, it entails, a priori, a processing outside the principle of legality since a third party is processing data, as they have access to it, without any legal basis.

For this reason, this is a process where the diligence provided by the operators is fundamental to prevent this type of fraud and violations of the GDPR. Diligence that translates into the establishment of adequate measures to ensure that data processing is in accordance with the GDPR.

In the present case, it can be inferred that DIGI has provided a duplicate SIM card to a third party different from the legitimate holder of the mobile line, after a third person has bypassed the existing security policy.

Denying the occurrence of negligent conduct on the part of DIGI would be equivalent to acknowledging that its behavior—by action or omission—has been diligent. Obviously, we do not share this perspective of the facts, as the lack of due diligence has been evidenced. The SAN of October 17, 2007 (rec. 63/2006) is very illustrative; starting from the premise that these are entities whose activity involves continuous processing of customer data, it indicates that "...the Supreme Court has understood that there is imprudence whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

Regarding the assertion that the criminals have not managed to obtain personal data through DIGI, and therefore it cannot be said that there has been a breach of protection measures, this cannot be considered true. It is necessary to point out that access to the duplicate of a SIM card that makes its holder identifiable corresponds to the definition of personal data in Article 4.1) of the GDPR.

As for DIGI's liability, it should be indicated that, in general, DIGI processes its customers' data under the provisions of Article 6.1 b) of the GDPR, as it is considered necessary for the execution of a contract in which the data subject is a party or for the application at their request of pre-contractual measures. In other cases, it bases the legality of the processing on the grounds provided in Article 6.1 a), c), e), and f) of the GDPR.

Certainly, the principle of responsibility provided in Article 28 of the LRJSP,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
10/19

It provides that: "Only individuals and legal entities may be sanctioned for acts constituting administrative infractions, as well as, when a law recognizes their capacity to act, affected groups, unions, and entities without legal personality, and independent or autonomous estates, that are found responsible for the same on the basis of intent or fault."

However, the manner of attributing responsibility to legal entities does not correspond to the forms of intentional or negligent culpability that are attributable to human behavior. Thus, in the case of infractions committed by legal entities, although the element of culpability must be present, it necessarily applies differently than it does with respect to individuals.

According to STC 246/1991 " (...) this distinct construction of the attribution of authorship of the infraction to the legal entity arises from the very nature of the legal fiction to which these subjects respond. They lack the volitional element in the strict sense, but not the capacity to infringe the norms to which they are subject. Capacity for infringement and, therefore, direct reproachability that derives from the legal good protected by the norm that is infringed and the necessity for that protection to be truly effective and the risk that, consequently, must be assumed by the legal entity that is subject to compliance with that norm" (in this sense, STS of November 24, 2011, Rec 258/2009).

To the above, it should be added, following the judgment of January 23, 1998, partially transcribed in the SSTS of October 9, 2009, Rec 5285/2005, and October 23, 2010, Rec 1067/2006, that "although the culpability of the conduct must also be subject to proof, it should be considered in relation to the assumption of the corresponding burden, that ordinarily the volitional and cognitive elements necessary to appreciate it are part of the proven typical conduct, and that their exclusion requires evidence of the absence of such elements, or in its normative aspect, that due diligence has been exercised by the one claiming its non-existence; in short, the mere invocation of the absence of fault is not sufficient for exculpation against typically unlawful behavior."

Consequently, the lack of culpability is dismissed. The ultimate responsibility for the processing remains attributed to the responsible party, who determines the existence of the processing and its purpose. Let us remember that, generally, operators process their customers' data under the provisions of Article 6.1 b) of the GDPR, as it is considered necessary processing for the execution of a contract in which the data subject is a party (...). In this regard, DIGI has a network of sales representatives, points of sale, and authorized distributors through a distribution contract to offer DIGI's services. Among these services offered from their points of sale is the issuance of duplicates of SIM cards corresponding to a mobile phone line.

Regarding the breach of the principle of proportionality, the GDPR expressly provides for the possibility of gradation, through the provision of fines that may be modulated, taking into account a series of circumstances of each individual case, the concurrence of which was duly motivated in the initiation agreement of the

11/19

present procedure.

Regarding the imposition of a warning, admonition, or the adoption of corrective measures in accordance with Article 58 of the GDPR, a deterrent fine is one that has a genuine deterrent effect. In this regard, the Judgment of the CJEU, dated June 13, 2013, Versalis Spa/Commission, C-511/11, ECLI:EU:C:2013:386, states:

"94. With respect, first of all, to the reference to the Showa Denko/Commission judgment, previously cited, it should be noted that Versalis interprets it incorrectly. In fact, the Court of Justice, by stating in paragraph 23 of that judgment that the deterrent factor is assessed taking into account a multitude of elements and not only the particular situation of the company in question, was referring to points 53 to 55 of the conclusions presented in that case by Advocate General Geelhoed, who essentially pointed out that the deterrent multiplier coefficient may aim not only at a 'general deterrence,' defined as an action to disincentivize all companies, in general, from committing the infringement in question, but also at a 'specific deterrence,' consisting of deterring the specific defendant from infringing the rules again in the future. Therefore, the Court of Justice merely confirmed, in that judgment, that the Commission was not obliged to limit its assessment to factors related solely to the particular situation of the company in question."

"102. According to established case law, the objective of the deterrent multiplier factor and the

consideration, in this context, of the size and global resources of the company in question lies in the desired impact on the aforementioned company, as the sanction must not be insignificant, especially in relation to the financial capacity of the company (in this sense, see, in particular, the judgment of June 17, 2010, Lafarge/Commission, C-413/08 P, Rec. p. I-5361, paragraph 104, and the order of February 7, 2012, Total and Elf Aquitaine/Commission, C-421/11 P, paragraph 82)."

We must take into account the singular circumstance of the claim presented, through which it can be verified that, from the moment the impersonating individual performs the substitution of the SIM, the victim's phone is left without service, transferring control of the line to the impersonators.

Consequently, their powers of disposal and control over their personal data are affected, which constitute part of the content of the fundamental right to data protection as indicated by the Constitutional Court in Judgment 292/2000, dated November 30, 2000 (FJ 7). Thus, by obtaining a duplicate of the SIM card, access to contacts or applications and services that have as a recovery procedure the sending of an SMS with a code to modify passwords is enabled under certain circumstances. Ultimately, they can impersonate the identity of the affected individuals, being able to access and control, for example: email accounts; bank accounts; applications such as WhatsApp; social networks, such as Facebook or Twitter, and a long etc. In summary, once the access key is modified by the impersonators, the victims lose control of their accounts, applications, and services, which poses a significant threat. Ultimately, it is the data controller who has the obligation to integrate the necessary guarantees in the processing, in order to, by virtue of the principle of proactive responsibility, comply and be able to demonstrate compliance, at the same time.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/19

time that respects the fundamental right to data protection.

III

Unfulfilled Obligation

Well, the respondent is accused of committing an infringement by violating Article 6 of the GDPR, "Lawfulness of processing," which states in its paragraph 1 the circumstances under which the processing of third-party data is considered lawful:

"1. Processing shall be lawful only if at least one of the following conditions is met:

- a) the data subject has given consent to the processing of their personal data for one or more specific purposes;
- b) processing is necessary for the performance of a contract to which the data subject is a party or in order to take steps at the request of the data subject prior to entering into a contract;
- c) processing is necessary for compliance with a legal obligation to which the data controller is subject;
- d) processing is necessary to protect the vital interests of the data subject or of another natural person;
- e) processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller;
- f) processing is necessary for the purposes of the legitimate interests pursued by the data controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular when the data subject is a child. The provision in point f) of the first paragraph shall not apply to processing carried out by public authorities in the performance of their tasks."

The issuance of a duplicate SIM card necessarily involves the processing of personal data, as it is carried out on the line and the identity of the holder. Such processing must comply with a legal basis that legitimizes it, as required by the aforementioned Article 6.1 of the GDPR.

In this case, the issuance of the duplicate SIM at the request of a third party without the intervention or consent of the holder constitutes a lack of valid legal basis for such data processing. Although DIGI claims to follow its own protocols, this is not sufficient to justify the lawfulness of the processing under the GDPR, as such protocols do not replace the need for the existence of a legitimate basis.

The identity verification procedure described by DIGI, which is based solely on the matching of certain

data in its database, does not adequately guarantee compliance with the GDPR in that:

- It does not prove the effective intervention of the data subject in the process.
- The mere matching of data does not ensure consent or any other legal basis under Article 6.1 that legitimizes the processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/19

Therefore, the issuance of the duplicate SIM under these conditions constitutes processing of personal data without a legal basis and, consequently, an infringement of Article 6.1 of the GDPR, given that it has been carried out without complying with any of the legitimizing bases for such processing. The responsibility does not lie in the failure to comply with an internal protocol of DIGI, but in the absence of a valid legal basis in accordance with the provisions of the GDPR.

In accordance with the evidence available, it is estimated that the conduct of the respondent violates Article 6.1 of the GDPR, which constitutes an infringement classified under Article 83.5.a) of the aforementioned Regulation 2016/679.

In this regard, Recital 40 of the GDPR states:

“(40) In order for processing to be lawful, personal data must be processed with the consent of the data subject or on some other legitimate basis laid down by law, whether in this Regulation or under the law of the Union or of the Member States to which this Regulation applies, including the necessity of complying with a legal obligation to which the data controller is subject or the necessity of performing a contract to which the data subject is a party or for the purposes of taking steps at the request of the data subject prior to entering into a contract.”

For the reasons stated, it is considered that DIGI has violated Article 6.1 of the GDPR.

IV

Classification and Qualification of the Infringement

The infringement is classified under Article 83.5 of the GDPR, which considers the following as such:

“5. Infringements of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 4% of the total annual global turnover of the preceding financial year, whichever is higher:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9.” The LOPDGD, for the purposes of the prescription of the infringement, qualifies in its Article 72.1 as a very serious infringement, with a prescription period of three years in this case, “b) The processing of personal data without any of the conditions for lawfulness of processing established in Article 6 of Regulation (EU) 2016/679.”

V

Sanction of Fine. Determination of the Amount

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

“Each supervisory authority shall ensure that the imposition of administrative fines under this Article for the infringements of this Regulation referred to in paragraphs 4, 9, and 6 is, in each individual case,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/19

effective, proportionate, and dissuasive.”

“Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those contemplated in Article 58, paragraph 2, letters a) to h) and j). In deciding the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the data processing operation in question, as well as the number of affected parties and the level of damage and harm they have suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the data controller or processor to mitigate the damage and harm suffered by the affected parties;
- d) the degree of responsibility of the data controller or processor, taking into account the technical or organizational measures they have applied under Articles 25 and 32;
- e) any previous infringement committed by the data controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the data controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the data controller or processor in relation to the same matter, the compliance with such measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement."

Regarding letter k) of Article 83.2 of the GDPR, the LOPDGDD, Article 76, "Sanctions and corrective measures," provides:

"2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The connection of the infringer's activity with the performance of personal data processing.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the data controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any affected party."

According to the transcribed provisions, for the purpose of determining the amount of the fine to be imposed on the respondent, as the responsible party for an infringement classified under Article 83.5.a) of the GDPR, the following factors are considered concurrent:

DIGI requests that the following mitigating circumstances be acknowledged:

- (I) "The respondent effectively resolved the incident subject to the complaint" (art. 83.2 c) GDPR).
- (II) "At no time were special categories of data processed" (art. 83.2 g).
- (III) "Cooperation with the supervisory authority by responding to the transfer of the complaint and providing the requested information," Article 83.2 f) of the GDPR.
- (IV) "The absence of benefits obtained through the infringement," Article 83.2 k) of the GDPR and 76.2 c) of the LOPDGDD.

None of the invoked mitigating factors are accepted.

The admission that it operates as a mitigating factor that the respondent has effectively resolved the incident subject to the complaint (Article 83.2 c) of the GDPR) partially nullifies the dissuasive purpose that is fulfilled through the sanction. Accepting DIGI's thesis in a case like the one at hand would imply introducing an artificial reduction in the sanction that truly should be imposed; the one that results from considering the circumstances of Article 83.2 GDPR that must indeed be evaluated.

In this case, the resolution of the incident was not carried out by DIGI's own initiative nor because this entity had detected the fraud by itself, but rather due to the intervention of the complainant who, upon

finding themselves without service, went to another point of sale to reactivate it. At that moment, a new duplicate of the SIM card was provided, which entails the cancellation of the previous one obtained fraudulently.

Article 83.2g) of the GDPR refers to "At no time were special categories of data processed."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/19

The data processed by DIGI are sensitive in nature. To identify its customers in the procedures for obtaining a duplicate SIM card, the data includes the name, surname, and ID number (DNI), which are personal data associated with a telephone line owned by a user. This data is obtained with the intention of impersonating the individual, which constitutes personal data whose unauthorized access is particularly serious. This is without prejudice to the fact that for the issuance of the duplicate of the aforementioned card, personal data such as the name, surname, and ID number of the holder have been processed.

Article 83.2.f) of the GDPR refers to the "degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement."

The response of the defendant to the information request from the Inspection Subdirectorate did not fulfill these purposes, and therefore cannot be classified under that mitigating circumstance.

Regarding the application of Article 76.2.c) of the LOPDGDD, in connection with Article 83.2.k), the non-existence of benefits obtained, it should be noted that such a circumstance can only operate as an aggravating factor and in no case as a mitigating circumstance.

Article 83.2.k) of the GDPR refers to "any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement." And Article 76.2.c) of the LOPDGDD states that "2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account: [...] c) The benefits obtained as a result of the commission of the infringement." Both provisions mention as a factor that can be considered in the grading of the sanction the "benefits" obtained, but not the "absence" of these, which is what DIGI claims.

Furthermore, according to Article 83.1 of the GDPR, the imposition of fines is governed by the following principles: they must be individualized for each particular case, be effective, proportionate, and deterrent. The admission that the absence of benefits operates as a mitigating factor is contrary to the spirit of Article 83.1 of the GDPR and to the principles governing the determination of the amount of the fine. If, as a result of the commission of a GDPR infringement, it is classified as a mitigating factor that no benefits existed, the deterrent purpose fulfilled through the sanction is partially nullified.

Accepting DIGI's thesis in a case like the one at hand would imply introducing an artificial reduction in the sanction that should genuinely be imposed; that which results from considering the circumstances of Article 83.2 of the GDPR that must indeed be evaluated.

The Administrative Litigation Chamber of the National Court has warned that the fact that in a specific case not all the elements that make up a modifying circumstance of responsibility, which by its nature has an aggravating character, are present, cannot lead to the conclusion that such a circumstance is applicable as a mitigating factor. The ruling made by the National Court in its SAN of May 5, 2021 (Rec. 1437/2020) -even though that resolution deals with the circumstance of section e) of Article 83.2 of the GDPR, the commission of previous infringements- is extrapolable to the issue raised, the claim of the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/19

Claimed that the "absence" of benefits should be accepted as a mitigating factor, given that both the GDPR and the LOPDGDD refer only to "the benefits obtained."

In order to assess the amount of the fine proposed to be imposed on DIGI for the infringement of Article 6.1 of the GDPR, we consider that the circumstances referred to below apply, which operate as aggravating factors:

- The circumstance of Article 83.2 e) GDPR: "Any previous infringement committed by the controller or the processor."

Recital 148 of the GDPR states that "In order to reinforce the application of the rules of this Regulation [...]" and indicates in this regard that "Special attention must, however, be paid to [...] or to any relevant previous infringement [...]".

Thus, in accordance with paragraph e) of Article 83.2 GDPR, in determining the amount of the administrative fine, all previous infringements of the controller or the processor must be taken into account in order to assess the unlawfulness of the analyzed conduct or the culpability of the infringing party.

Moreover, a correct interpretation of the provision of Article 83.2.e) GDPR cannot overlook the purpose pursued by the regulation: to decide the amount of the administrative fine in the individual case presented, always ensuring that the sanction is proportional, effective, and dissuasive.

There are numerous sanctioning procedures processed by the AEPD in which the claimed party has been sanctioned for the infringement of Article 6.1 GDPR:

i. EXP 202104009 Resolution issued on March 15, 2023, in which a fine of 70,000 euros was imposed. The facts concerned a fraudulent duplicate of the SIM card without legitimacy.

ii. EXP 202201226. Resolution issued on March 14, 2023, in which a fine of 70,000 euros was imposed. The facts concerned a fraudulent duplicate of the SIM card without legitimacy.

iii. EXP 202204881 Resolution issued on June 2, 2023, in which a fine of 70,000 euros was imposed. The facts concerned a fraudulent duplicate of the SIM card without legitimacy.

- The evident link between the business activity of the claimed party and the processing of personal data of clients or third parties (Article 83.2.k of the GDPR in relation to Article 76.2.b of the LOPDGDD).

The business activity of the claimed party necessarily involves the processing of personal data, being a very important telecommunications company in Spain. This characteristic of its business activity impacts, reinforcing it, the diligence that must be exercised in compliance with the principles governing the processing of personal data and in the quality and effectiveness of the technical standards and regulations.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
18/19

organizational measures that must be implemented to guarantee respect for the fundamental right. The Judgment of the National Court of 17/10/2007 (rec. 63/2006), in which, regarding entities whose activity involves continuous processing of customer data, indicates that "...the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the offender does not behave with the required diligence. And in assessing the degree of diligence, special consideration must be given to the professionalism or lack thereof of the subject, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

It is appropriate to grade the sanction to be imposed on the defendant and set it at the amount of €200,000 for the infringement of Article 83.5 a) of the GDPR, classified as very serious for the purposes of prescription in Article 72.1b) of the LOPDGDD.

Therefore, in accordance with the applicable legislation and having assessed the criteria for grading the sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on DIGI SPAIN TELECOM, S.L. with NIF B84919760, for an infringement of Article 6.1 of the GDPR, classified under Article 83.5 of the GDPR, a fine in the amount of €200,000

(two hundred thousand euros).

SECOND: TO NOTIFY this resolution to DIGI SPAIN TELECOM, S.L. with NIF B84919760.

THIRD: This resolution will be executive once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has elapsed without the interested party having exercised this right.

The sanctioned party is warned that they must pay the imposed sanction once this resolution is executive, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No. IBAN:

ES00-0000-0000-0000-000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once it is executive, if the date of executivity falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day thereafter.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/19

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension will be considered terminated.

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es